1 Censorship (& Privacy)

1.1 Einführung in Internetzensur

Internetzensur beschränkt, welche Informationen im Internet veröffentlicht oder abgerufen werden können[cite: 40]. Sie wird von Regierungen und Organisationen eingesetzt[cite: 41].

Ziele der Zensur

- **Schutz von Rechten:** Blockierung urheberrechtlich geschützter Inhalte[cite: 41].
- **Sicherheit:** Schutz vor schädlichen oder sensiblen Inhalten (z. B. Malware, illegale Pornografie)[cite: 41].
- **Politische Kontrolle:** Einsatz als Propagandamethode zur Förderung spezifischer religiöser oder politischer Agenden[cite: 42].

Die Umsetzung erfolgt in vier Hauptkategorien:

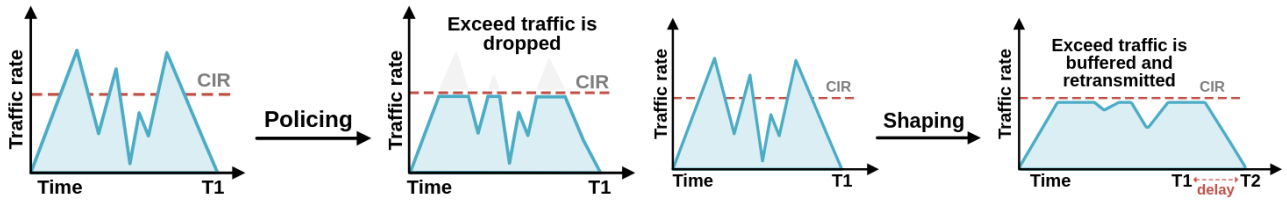
1. **Drosselung (Throttling):** Verlangsamung des Datenverkehrs[cite: 44].
2. **Blockierung:** Verhindern des Zugriffs auf spezifische Verbindungen[cite: 44].
3. **Entfernung:** Löschung von Inhalten[cite: 44].
4. **Abschaltung:** Vollständige Abschaltung des Internets[cite: 45].

1.2 Drosselung des Datenverkehrs (Throttling)

Die Drosselung reduziert die dem Netzwerkverkehr zugewiesene Bandbreite[cite: 52]. Sie ist diskreter als eine vollständige Blockierung und oft schwerer als absichtliche Zensur zu erkennen, da sie zufällig oder absichtlich wirken kann[cite: 52, 53]. Sie kann geografisch oder App-basiert gezielt eingesetzt werden[cite: 52].

Es gibt zwei technische Hauptmethoden zur Durchsetzung von Ratenlimits:

- **Traffic Shaping**: Verzögert Pakete, die das zugewiesene Ratenlimit überschreiten[cite: 75, 76].
- **Traffic Policing**: Verwirft Pakete (dropped), die das Ratenlimit überschreiten[cite: 76].



1.3 Blockierung von Verbindungen

1.3.1 Domain-Entfernung

Behörden können Nameserver dazu zwingen, Domains aus ihren Verzeichnissen zu entfernen[cite: 102].

1.3.2 DNS-Manipulation

- **DNS Injection (via Man-on-the-Side):** Zielt auf das DNS-Protokoll ab[cite: 125]. Der Zensor fängt DNS-Anfragen für verbotene Domains ab und schleust eigene Antworten (mit falschen IP-Adressen) ein[cite: 103, 125].
- **DNS Filtering:** Der DNS-Nameserver selbst steht unter der Kontrolle des Zensors[cite: 138]. Es ist kein Abfangen und Injizieren erforderlich, da der Server direkt die falsche IP-Adresse liefert[cite: 138].

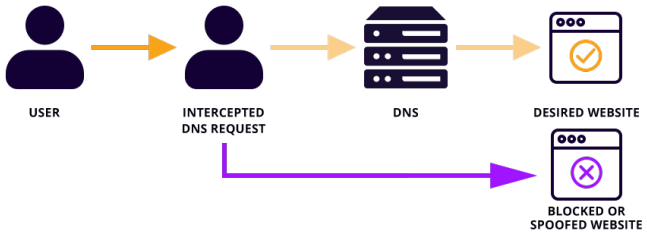


Figure 1: *Injection*

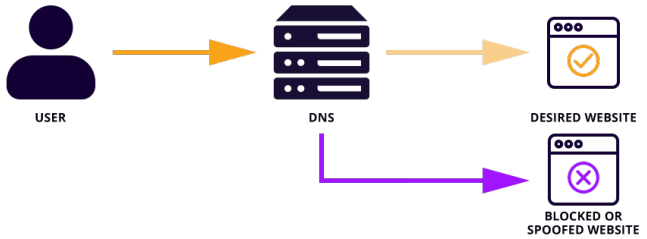


Figure 2: *Filtering*

1.3.3 Man-on-the-Side (MotS) für HTTP

Ablauf eines MotS-Angriffs

1. Der Client initiiert eine legitime HTTP-Anfrage[cite: 110].
2. Der Zensor (hat Zugriff auf den Kanal, kann aber Pakete nicht ändern/löschen [cite: 108]) fängt die Verbindung ab und injiziert ein TCP-Segment, um den Client umzuleiten[cite: 110].
3. Dieses injizierte Paket erreicht den Client vor der legitimen Antwort des Webservers, welche daraufhin verworfen wird[cite: 110].
4. Der Client landet auf einem bösartigen Webserver[cite: 111].

1.3.4 BGP Hijacking

Behörden leiten den Internetverkehr für bestimmte Ziel-Präfixe oder autonome Systeme um oder blockieren ihn[cite: 104]. **Beispiel:** Pakistan versuchte 2008 YouTube durch eine "False Origin Announcement" (falsche Präfix-Ankündigung) zu blockieren, was den globalen Traffic umlenkte[cite: 149, 159, 160].

1.3.5 IP-Blocking

Behörden weisen Internetanbieter (ISPs) an, den Zugriff auf bestimmte IP-Adressen zu blockieren[cite: 105, 175]. Dies kann auch auf dem Endgerät oder durch einen MotS-Angreifer geschehen[cite: 173, 176].

1.4 Entfernung von Inhalten

Inhalte können auf Anfrage von Regierungsbehörden (Gerichte, Exekutive, Polizei) aus dem Internet entfernt werden[cite: 215, 221, 224, 287]. Häufige Gründe umfassen nationale Sicherheit, Urheberrecht, Verleumdung und Privatsphäre[cite: 189, 190, 191, 193].

1.5 Zensur-Werkzeuge und Technologien

1.5.1 Deep Packet Inspection (DPI)

Deep Packet Inspection (DPI)

DPI ist im Datenpfad ("on-path") positioniert[cite: 304]. Es hat vollen Zugriff auf Paket-Header, nutzt Quell-/Zielports sowie IP-Adressen und kann den Paket-Payload analysieren[cite: 299, 300, 301]. Es sucht nach Mustern, Fingerabdrücken und verbotenen Schlüsselwörtern[cite: 302].

DPI und Verschlüsselung: DPI kann verschlüsselte Payloads nicht ohne die richtigen Schlüssel entschlüsseln[cite: 317]. Durch KI und ML kann DPI jedoch:

- Verkehrsverbindungen über Metadaten und Handshake-Muster analysieren[cite: 318].
- Netzwerkfluss-Statistiken auswerten (z. B. Erkennung von Botnetzen)[cite: 320, 321].
- Verschleierungstechniken wie Tor oder VPN erkennen[cite: 322].
- Fingerprinting (z. B. JA4/JA4+) für SSL/TLS-Verbindungen nutzen[cite: 322, 323].

Nachteile: Rechenintensiv, zeitaufwendig und abhängig von vortrainierten KI/ML-Modellen (unzuverlässig bei unbekannten Angriffen)[cite: 334, 335, 336].

1.5.2 Zwangsfilterung

Kann auf Infrastrukturebene (ISP, DNS, BGP) geschehen oder durch zwangsweise installierte Software auf Endgeräten[cite: 339, 340]. Regularien in der EU umfassen die Urheberrechtsrichtlinie (Art. 17) und den Digital Services Act (DSA)[cite: 349, 350].

1.6 Fallstudie: China

1.6.1 Great Firewall of China (GFW)

Befindet sich im Datenpfad zwischen China und dem globalen Internet[cite: 378]. Untersucht den Inhalt ausgehender Pakete[cite: 379].

- Bei erkannten illegalen Inhalten in TCP-Verbindungen wird ein **RST-Paket** gesendet (Verbindungsabbruch)[cite: 381].
- Nutzt IP-Blocking und DPI-Heuristiken zur Analyse verschlüsselten Verkehrs[cite: 382, 383].

1.6.2 Great Cannon (GC)

Ein In-Path-System mit vollständigen MitM-Fähigkeiten (Man-in-the-Middle)[cite: 405].

- Es bewaffnet den Datenverkehr unbeteiligter externer Nutzer, die chinesische Websites besuchen[cite: 409].
- Injiziert bösartigen Code (JavaScript), um DDoS-Angriffe gegen Zensur-Kritiker (z. B. GitHub) zu starten[cite: 408].

1.7 Privacy: Grundlagen

Privacy

Laut NIST: Die Zusicherung, dass die Vertraulichkeit von und der Zugang zu bestimmten Informationen über eine Entität geschützt ist[cite: 460, 463]. Anwendungsbereiche umfassen Networking (z. B. VPN, Tor), Datenbanken (Federated Learning) und Kryptographie[cite: 470, 471, 472].

1.8 Networking: The Onion Routing (TOR)

TOR bietet stark gegen Überwachung und Verkehrsflussanalyse geschützte, anonyme Verbindungen[cite: 637].

Funktionsweise des Onion Routing Protokolls

1. Der Tor-Client bezieht eine Liste von Knoten (Nodes) von einem Directory Server[cite: 670, 671].
2. Der Client wählt einen zufälligen Pfad durch das Netzwerk[cite: 689]. Der Verkehr wird über einen **Entry Guard**, ein **Middle Relay** und ein **Exit Relay** geleitet[cite: 802, 803, 821].
3. Pakete werden mehrlagig (wie eine Zwiebel) mit den Schlüsseln der Knoten verschlüsselt[cite: 788]. Jeder Knoten entschlüsselt eine Schicht.

Wissensverteilung im Pfad:

- **Entry Guard:** Kennt die IP des Nutzers, aber nicht den Zielserver[cite: 868].
- **Middle Relay:** Kennt nur Entry und Exit Relay (weder Nutzer noch Ziel)[cite: 868].
- **Exit Relay:** Kennt den Zielserver (Web Server) und entschlüsselt die letzte Schicht (kann Daten lesen, falls kein HTTPS genutzt wird), kennt aber den Nutzer nicht[cite: 868].

Tor-Bridges: Wenn öffentliche Entry Guards blockiert sind, können Nutzer **Bridges** (nicht öffentlich gelistete IP-Adressen) verwenden[cite: 727, 728]. Diese werden über alternative Kanäle wie Telegram verteilt und in nicht überschneidenden Buckets mit Ratenbegrenzung vergeben[cite: 745, 770].

1.8.1 TOR Services (Hidden Services)

Ermöglichen es, Websites (.onion-Adressen) anonym anzubieten. Weder Inhalt noch Identität/Standort des Servers sind sichtbar[cite: 875].

- **Intro Points:** Der Hidden Server verbindet sich über Tor-Relays mit sogenannten **Intro Points**[cite: 880, 881]. Eine signierte Liste dieser Intro Points wird im Directory veröffentlicht[cite: 897].
- **.onion-Adresse:** Die Adresse enthält (seit Version 3) den vollständig Base32-enkodierten öffentlichen Schlüssel des Servers, eine Versionsnummer und eine Checksumme[cite: 953, 954]. Die Checksumme schützt vor Tippfehlern[cite: 965].
- **Verbindungsaufbau:** Der Client bestimmt einen **Rendezvous Point** und teilt diesem ein Einmal-Geheimnis (Secret String) mit[cite: 972, 975]. Der Client sendet diese Infos über die Intro Points an den Service[cite: 988]. Der Service verbindet sich mit dem Rendezvous Point und sendet den Secret String[cite: 1003, 1004]. Bei Übereinstimmung sind beide Parteien doppelt anonym über Tor verbunden[cite: 1005, 1023, 1024].

Anonymitätsgrenzen in TOR: TOR bietet keine perfekte Anonymität[cite: 1044].

- **Website Fingerprinting:** Ein lokaler Angreifer (z. B. lokaler ISP) analysiert Verkehrsmuster, um die besuchte Website zu erraten[cite: 1050].
- **Sybill/Eclipse Angriff:** Wenn ein Angreifer eine große Menge von Eingangs- und Ausgangsknoten kontrolliert, können Datenströme korreliert werden[cite: 1045].
- **Self-Deanonymization:** Nutzer deanonymisieren sich selbst durch Metadaten (Browserversion) oder ihr Verhalten[cite: 1046, 1047].

1.9 Datenschutz in Datenbanken: Federated Learning

Das Zentralisieren großer Datenmengen (z. B. Gesundheitsdaten) verstößt oft gegen Datenschutzgesetze[cite: 1145, 1160]. Lokales Training von Machine Learning (ML) Modellen ist jedoch problematisch, da kleine Datensätze verzerrt sind und Modelle schlecht generalisieren[cite: 1151, 1152].

Federated Learning

Ein dezentrales ML-Framework[cite: 1164]. Clients (z. B. Krankenhäuser) trainieren Modelle auf ihren **lokalen Daten**[cite: 1165]. Es werden **nur die Modellgewichte** (Updates) an einen zentralen Server gesendet[cite: 1165]. Der Server aggregiert diese zu einem globalen Modell[cite: 1165]. Die Rohdaten verlassen nie die lokale Umgebung[cite: 1164].

Sicherheitsprobleme: Modellupdates können sensible Informationen preisgeben[cite: 1198]. Ein Insider (z. B. ein ehrlicher, aber neugieriger Client) kann in sequenziellen Trainingszyklen **Membership-Inference Angriffe** durchführen, um festzustellen, ob bestimmte Datenpunkte Teil des Trainingsdatensatzes einer anderen Partei waren[cite: 1200, 1201].

Gegenmaßnahme - Differential Privacy (DP):

- Begrenzt mathematisch den Einfluss einzelner Personen auf das Endergebnis, indem **Rauschen** hinzugefügt wird[cite: 1247, 1248].
- *Data Suppression:* Löscht bestimmte Eigenschaften (schützt Personen, die im Datensatz sind)[cite: 1250, 1251].
- *Data Perturbation:* Fügt Rauschen hinzu oder ersetzt Werte (schützt sowohl Personen im Datensatz als auch außerhalb)[cite: 1252, 1253].

1.10 Kryptographie: Homomorphe Verschlüsselung

Homomorphic Encryption

Ermöglicht es, Berechnungen **direkt auf verschlüsselten Daten (Chiffretext)** durchzuführen, ohne sie vorher zu entschlüsseln[cite: 1259, 1260]. Das Ergebnis der Berechnung entspricht nach dem Entschlüsseln dem Ergebnis, das bei einer Berechnung auf Klartextdaten entstanden wäre[cite: 1260].

Arten der homomorphen Verschlüsselung:

- **Full homomorphic Encryption (FHE):** Unterstützt unbegrenzte Additions- und Multiplikationsoperationen[cite: 1291]. Erlaubt beliebige Berechnungen, ist aber derzeit extrem ressourcenintensiv[cite: 1291, 1292].
- **Somewhat homomorphic Encryption (SHE):** Unterstützt Addition und Multiplikation nur für eine begrenzte Anzahl von Operationen[cite: 1293]. Ist schneller, wird aber durch die Akkumulation von Rauschen im Chiffretext limitiert[cite: 1294].
- **Partially homomorphic Encryption (PHE):** Unterstützt unbegrenzt **nur eine** Art von Operation (entweder Addition oder Multiplikation)[cite: 1295].